

RFC: 8446

ASSIGNMENT 3

HOLONET TLS HANDSHAKE

HoloNet TLS Specification

This system allows for a user to connect to a key exchange hosted for allowing secure connections to the HoloNet. This system allows for encrypted communications to occur without the loss of confidentiality of traffic.

Network Access

This system utilizes port 2302 for the key exchange and 2305 for the HoloNet gateway. Clients are expected to contact the key exchange for an RSA key. This RSA key can then be used to acquire an AES key. Since the communication must be expected to be reliable with recent traffic in the case of a loss of integrity, TCP is used.

Each connection is handled on a different thread which utilizes an ephemeral remote port assigned from the core handshake. This allows the server to handle as many connections as there are threads available on the server itself. Additionally, it prevents the need for the server to be reopened in the case of terminal connection failures.

The server responsible for this system is located at 34.197.176.87 and is hosted using a Cloud service. It should be available and any loss of service should be reported to chumme2@lsu.edu.

Security Features

The HoloNet TLS has a special behavior to prevent exploitation by the Rebel Alliance. The time-to-live for an AES key to survive to start the initial connection is incredibly small. This means that an active connection to the production version will need to be incredibly short. Additionally, the traffic expectation is rigid with non-compliant messages being dropped entirely.

Message Types

These are the message codes that are used in relation to the HoloNet key exchange. In the case of communication, message codes are exchanged to their matching number so a MC_INITIATE will be met with a MC_RESPONSE_INITIATE and a MC_EXCHANGE will be met with a MC_RESPONSE_EXCHANGE. All connections are ended with a MC_CONNECTION_END message code.

Message Code	Message
0x01	MC_INITIATE
0x02	MC_EXCHANGE
0x03	MC_RESPONSE_INITIATE
0x04	MC_RESPONSE_EXCHANGE
0x05	MC_CONNECTION_END

Response Codes

These are the response codes that are used in HoloNet cryptographic security protocols. These are sent to indicate any errors or whether traffic has been understood correctly by the server. These response codes indicate that the size of the message isn't accurate to its length, whether the values are not in their appropriate location, or if the wrong key was used for communication.

Response Code	Response
0x00	Operation was successful; no error
0x01	ERR: Invalid Length
0x02	ERR: Unknown Format
0x03	ERR: Bad Key

Security Posture Code

These are the security posture codes used for communication with the HoloNet cryptographic suite. They are used to indicate the level of security being implemented to ensure that appropriate security measures are being used at the right levels. Security cannot be downgraded for RSA/AES communication requests.

Security Code	Security Posture
0x00	Not Encrypted
0x01	RSA Encrypted
0x02	AES Encrypted

Unknown Flag

There's a flag that has not yet been published by the Imperial Security Bureau. All we know is that the value is to be set to either 0x00 or 0x01 to have it function correctly for any client communications to the server. A 0x00 will return the receipt flag.

Unk Code	Unknown
0x00	False
0x01	True

UNENCRYPTED INIT MESSAGE (0x01)

Unencrypted Initialization messages are used to establish communication with the key exchange on the HoloNet. They contain a message code of 1 for a transmission. A response code will detail any errors on transmission. A security posture code will detail the level of security (in this case being 0). There is also an unknown value whose purpose is unknown. The name is a value made up of the first character of the last name and up to 7 characters of the first name. If a first name is longer than 7 characters, the first 7 characters of the first name are used and if its shorter than 7 characters, then the combination of the last name character and the first name are to be preceded by ‘_’ characters. An example would be ‘__SJohn’.

UNENCRYPTED INIT MESSAGE (Request)

Response	Length of Bytes
Message Code	1
Response Code	1
Security Posture Code	1
Unknown Flag	1
Name	8

RSA RESPONSE MESSAGE (0x03)

RSA keys are issued in response to the initialization message. None of the flags carried over from the original message are expected to change. However, the name value has been omitted for a port and key value. The port containing the next port for which contact must be made in order to reconnect with the key exchange to acquire the AES key. The key value contains the public key of the RSA server so that traffic can be sent back securely.

RSA RESPONSE MESSAGE (Response)

Response	Length of Bytes
Message Code	1
Response Code	1
Security Posture Code	1
Unknown Flag	1
Port	4
Key	162

AES REQUEST MESSAGE (0x02)

AES keys are issued in response to an exchange request made to the key exchange service on the previously acknowledged port in the response. The message code is changed to acknowledge an exchange is occurring to that of 0x02. The response code and unknown flag are to remain unchanged to function properly. The security posture flag must be set to 1 to indicate that an RSA exchange is occurring. The request need not be encrypted in this transfer.

AES REQUEST MESSAGE (Request)

Response	Length of Bytes
Message Code	1
Response Code	1
Security Posture Code	1
Unknown Flag	1
Port	4
Key	162

AES RESPONSE MESSAGE (0x04)

This message will be sent back in response to the AES Request Message. The message code is expected to be 0x04, the response code and unknown flag can remain the same as before, and the security posture must remain at 0x01. The port should be heeded for the next communication to access the HoloNet. The key value will consist of a 128 byte RSA-encrypted data. Consequently, when the key value is decrypted, it can be broken down to the 16 byte AES key and the 64 byte HMAC. Verification of the HMAC is user-dependent, but is not required to continue onwards. The 16 byte AES key is loaded into the AESKey library to then encrypt according to the next message's instructions.

RSA REQUEST MESSAGE (Request)

Response	Length of Bytes
Message Code	1
Response Code	1
Security Posture Code	1
Unknown Flag	1
Port	4
Key	128

ENCRYPTED INIT MESSAGE (0x01/0x03)

The message code, response code, and unknown flag are to mirror the previous case of the unencrypted init message to achieve correct behavior. For the Enc_Name, the name originally used in the first init will be encoded in UTF-8 then padded before being encrypted. In a similar manner, a receipt will be sent back which will need to be decrypted and unpadded afterward, if necessary.

ENCRYPTED MESSAGE (Response)

Response	Length of Bytes
Message Code	1
Response Code	1
Security Posture Code	1
Unknown Flag	1
Enc_Name	32

ENCRYPTED MESSAGE (Response)

Response	Length of Bytes
Message Code	1
Response Code	1
Security Posture Code	1
Unknown Flag	1
Receipt	32

Notes

1. In a real TLS scenario, sharing the public key isn't cryptographically insecure since only the private key can decrypt traffic. This can be explored in greater detail in a more focused Cryptographic course, but for networking, the specifics for RSA/AES don't matter. Just know that you encrypt with public and decrypt with private for RSA and that you can use the AES key that's shared to encrypt/decrypt at will.
2. Time delays for key traffic are not always 30 seconds with additional safeguards being implemented in real systems such as the use of PIDs, tokens, or other resources to secure them from MitM attacks.
3. Your flag will always be in the format of "flag{...}".
4. The RSA keys are being sent in the DER format to be more succinct in transfer. If you're curious about this functionality, research the difference between PEM and DER encodings.
5. Yes, this TLS exchange is not very secure, it's not designed to be. Use it as a set of lessons to demonstrate what to do and what not to do.
6. The unknown flag might do something, but its not necessary to solve the flag. Keep it 0 if you want to just complete the assignment.
7. If you get a flag back from the live version, your attempt will be logged with your name and show that you completed it successfully. This should make grading easier and make attempts easier to log for all.